

TP4 — Audit de conformité des licences

Prérequis

- **Projet** : TP1, TP2, TP3 ou votre projet fil rouge, au choix.
- **Dépendances** : aucune n'est ajoutée. Le travail porte sur l'audit de l'existant.

Objectif

Appliquer un audit exhaustif et automatisé des licences de toutes les dépendances du projet choisi, transitives comprises, puis documenter une décision pour tout cas problématique détecté.

Outils

Utilisez le scanner correspondant à l'écosystème du projet choisi :

- **.NET** : dotnet-project-licenses
 - Exemple d'appel : `dotnet-project-licenses -i .`
- **JavaScript** : license-checker
 - Exemple d'appel : `npx license-checker --summary`
- **Python** : pip-licenses
 - Exemple d'appel : `pip-licenses --format=markdown`

Travail demandé

1. Scannez l'intégralité des dépendances du projet choisi (directes et transitives) avec l'outil correspondant à son langage. Exportez le résultat dans un fichier (`licenses.md` ou `licenses.json`).
2. Classez chaque licence trouvée dans l'une des trois familles vues en cours : permissive, copyleft, propriétaire. Signalez explicitement toute licence copyleft (GPL, AGPL, LGPL) ou non identifiée par l'outil.
3. Rédigez, pour chaque cas copyleft détecté — ou, si aucun n'apparaît dans le projet choisi, sur un cas fourni en TD — une fiche de décision indiquant :
 - le nom du package et sa position dans l'arbre de dépendances (directe ou transitive, et à quelle profondeur) ;
 - la stratégie retenue parmi : réécrire, substituer par un équivalent permissif, isoler derrière une interface existante, ou négocier une licence alternative ;

- la justification du choix au regard de l'architecture déjà en place (boundary, adaptateur), si applicable au projet choisi.
4. Intégrez le scan en CI : le build doit échouer si une licence absente d'une liste blanche que vous définissez (ex. MIT, Apache-2.0, BSD) apparaît dans le résultat.

Livrable

Un rapport contenant : le fichier de scan brut, le tableau de classification, la ou les fiches de décision, et la configuration CI ajoutée.

Critère de réussite

Le build échoue si un package sous licence copyleft non whitelisted est ajouté au projet — vérifiez-le en ajoutant volontairement un package GPL de test, puis en le retirant.